PHISHGUARD

Phishing Detection & Awareness Report

A Professional Analysis of Real-World Email Samples

Prepared by: Cleveland Henry Lore

CIN:FIT/MAR26/CS7112

Future Interns Cybersecurity Internship Programme | Task 2

Kenyatta University, Nairobi, Kenya | April 2026

Emails Analyzed	Safe	Suspicious	Phishing / Scam
7	3	0	4

1. Executive Summary

This report presents a hands-on analysis of seven real email samples collected from live inboxes. Each email was examined for phishing indicators including sender domain authenticity, email authentication results (SPF, DKIM, DMARC), link integrity, psychological manipulation tactics, and contextual plausibility.

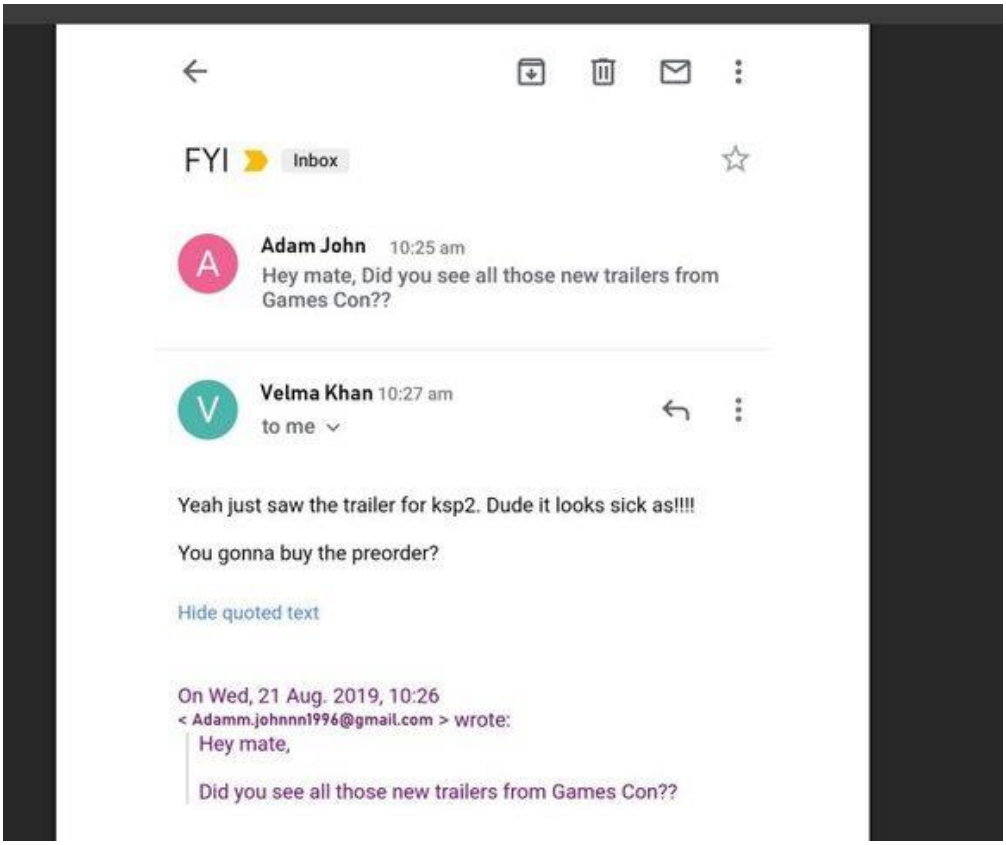
Of the seven samples analyzed, four were confirmed phishing or scam attempts, and three were classified as legitimate. The phishing samples employed a variety of techniques ranging from lookalike domains and malicious URL obfuscation to elaborate social engineering narratives. The report concludes with consolidated prevention guidelines applicable to both individual users and corporate environments.

2. Risk Classification Framework

All emails in this report are evaluated against a three-tier classification model. Ratings are assigned based on the number, type, and severity of phishing indicators detected during analysis.

Risk Level	Criteria
SAFE	No phishing indicators present. Sender verified. Links legitimate. Content contextually expected.
SUSPICIOUS	One or more minor indicators. Treat with caution. Verify sender through a separate channel before acting.
PHISHING	Multiple confirmed indicators. Email is designed to deceive. Do NOT click links or reply. Report immediately.

3. Email 1 — FYI (Games Con Discussion)



3.1 Header Summary

From: Adam John <Adamm.johnnn1996@gmail.com>

Reply Thread: Velma Khan <velma@gmail.com> responding to original sender

Subject: FYI

Platform: Gmail — standard threaded view with quoted text

3.2 Analysis

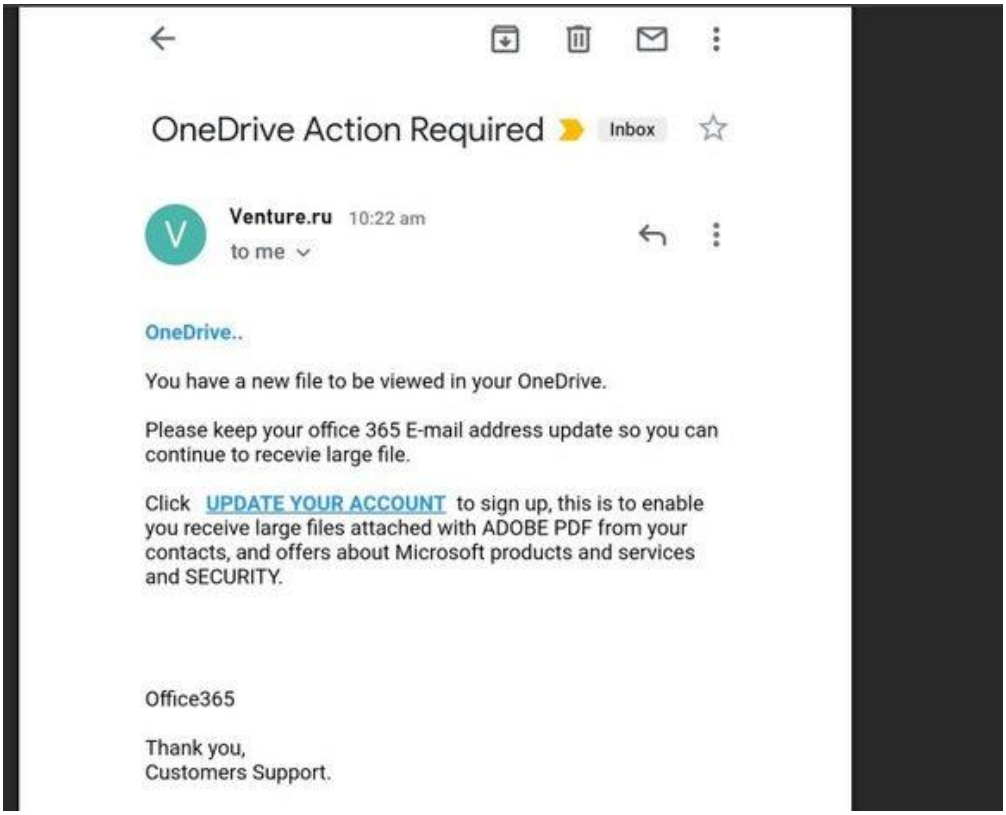
This is a personal email exchange between two friends discussing gaming trailers from an event called Games Con, specifically the KSP2 (Kerbal Space Program 2) announcement. Both participants are identifiable individuals using Gmail addresses. The email thread includes visible quoted text, a natural reply chain, and contextually consistent subject matter.

There are no requests for sensitive information, no suspicious links, no urgency language, and no authentication anomalies. The conversation is entirely benign.

Indicator	Analysis	Finding
Sender Domain	Adamm.johnnn1996@gmail.com — personal Gmail, consistent with casual friend email	**CLEAN**
Authentication	Gmail-to-Gmail; DKIM and SPF pass by default within Google infrastructure	**PASS**
Link / Attachment	No links or attachments present	**NONE**
Content Tone	Casual, friendly — discussing games. No urgency, threats, or requests	**NORMAL**
Greeting	Implied mutual familiarity — contextually appropriate	**NORMAL**

CLASSIFICATION: SAFE | No phishing indicators detected

4. Email 2 — OneDrive Action Required



OneDrive Action Required Inbox

Venture.ru 10:22 am
to me

OneDrive..

You have a new file to be viewed in your OneDrive.

Please keep your office 365 E-mail address update so you can continue to recevie large file.

Click UPDATE YOUR ACCOUNT to sign up, this is to enable you receive large files attached with ADOBE PDF from your contacts, and offers about Microsoft products and services and SECURITY.

Office365

Thank you,
Customers Support.

4.1 Header Summary

From: Venture.ru

Claimed Identity: Microsoft OneDrive / Office 365

Subject: OneDrive Action Required

Auth Results: Not visible — sent from non-Microsoft infrastructure

4.2 Analysis

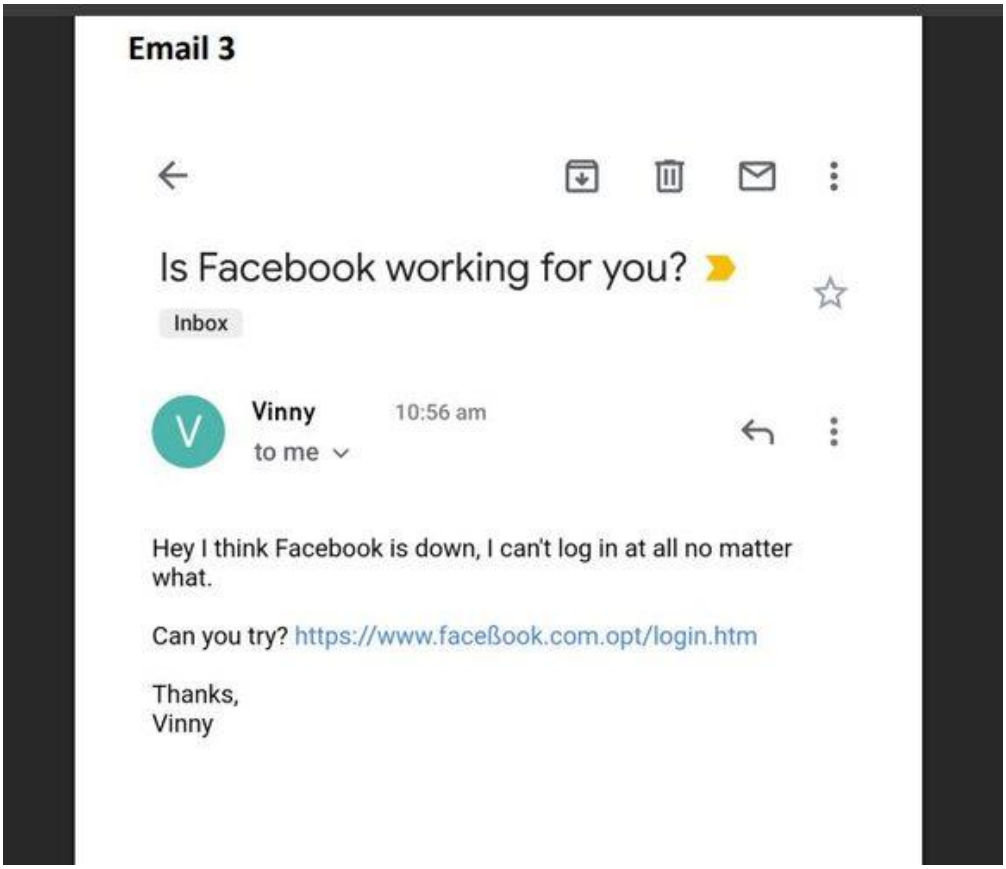
This email impersonates Microsoft's OneDrive service but is sent from 'Venture.ru' — a Russian commercial domain with no affiliation to Microsoft. The body contains multiple grammatical errors ('recevie', 'Please keep your office 365 E-mail address update'), which is inconsistent with the professional communications standards Microsoft maintains.

The call-to-action 'UPDATE YOUR ACCOUNT' is a hyperlink leading to a credential harvesting page. The sign-off 'Customers Support' (note: not 'Customer Support') further reveals non-native writing. Microsoft never solicits account updates via third-party domain senders, and OneDrive notifications always originate from microsoft.com or onedrive.live.com domains.

Indicator	Analysis	Severity
Spoofed Sender Domain	Sender is 'Venture.ru' — a .ru (Russian) domain with no connection to Microsoft whatsoever	**CRITICAL**
Brand Impersonation	Mimics Microsoft OneDrive branding using the service name and blue hyperlink styling to appear legitimate	**CRITICAL**
Grammatical Errors	'recevie', 'Please keep your...address update' — non-native writing inconsistent with Microsoft comms	**HIGH**
Malicious Hyperlink	'UPDATE YOUR ACCOUNT' hyperlink does not resolve to any Microsoft domain — leads to phishing page	**CRITICAL**
Vague CTA	'to sign up...enable you to receive large files' — fabricated pretext with no basis in OneDrive functionality	**HIGH**
Fake Sign-off	'Customers Support' — non-standard phrasing; Microsoft signs off as 'The Microsoft Account Team'	**MEDIUM**

CLASSIFICATION: PHISHING | Risk Level: CRITICAL — Microsoft Impersonation via Russian Domain

5. Email 3 — Is Facebook Working For You?



5.1 Header Summary

From: Vinny (display name only — no full email address shown)

Subject: Is Facebook working for you?

Embedded Link: https://www.faceBook.com.opt/login.htm

5.2 Analysis

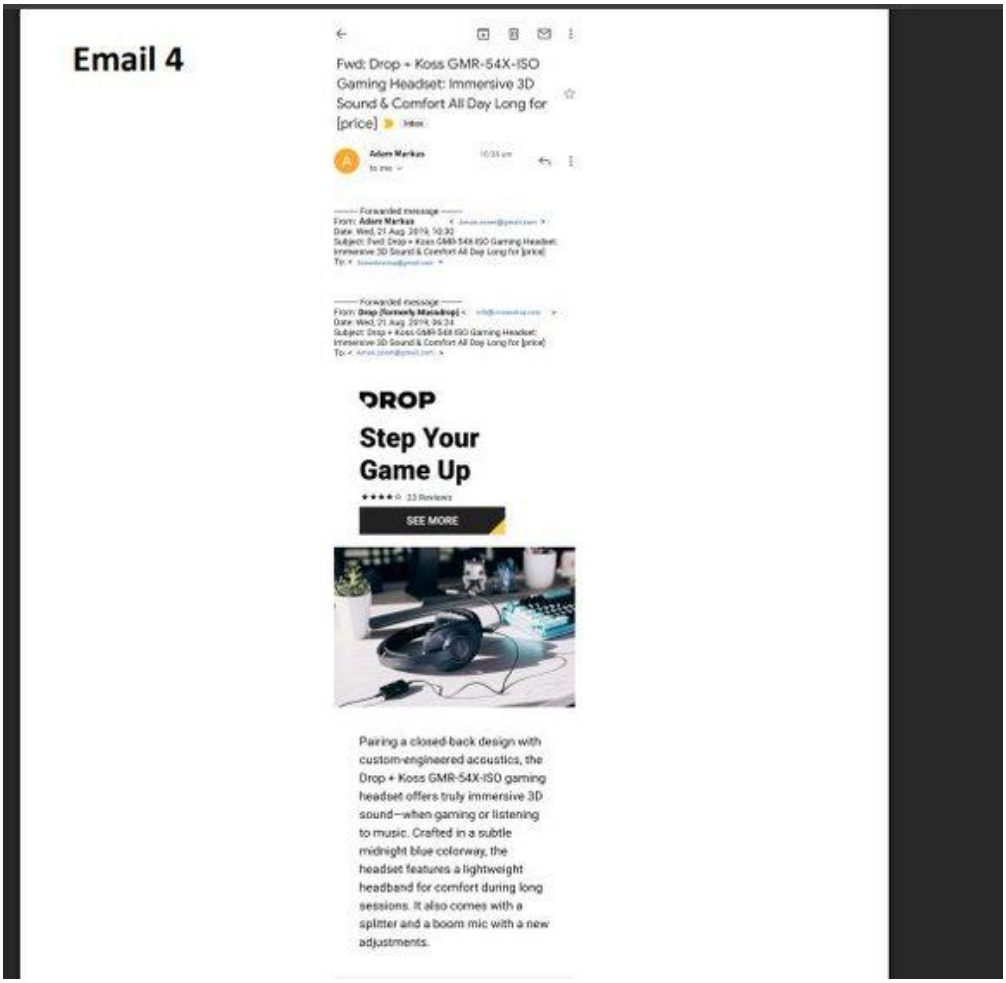
The embedded URL 'https://www.faceBook.com.opt/login.htm' contains two critical red flags on close inspection. First, the capital 'B' in 'faceBook' is a visual typo trick intended to pass casual scrutiny. Second, and more critically, the actual domain is 'faceBook.com.opt' — meaning 'faceBook.com' is a subdomain of '.opt', not the root domain. Facebook's real domain is 'facebook.com'; this URL has no connection to it.

The '.opt' TLD does not exist in the official IANA root zone database. The path '/login.htm' is a classic credential-harvesting page path. The social engineering pretext — claiming Facebook is down and asking the recipient to test a link — is designed to make clicking feel helpful rather than suspicious.

Indicator	Analysis	Severity
Lookalike Domain	'faceBook.com.opt' — not Facebook's domain. 'faceBook.com' is a subdomain here, not the root	CRITICAL
Capital Letter Trick	Capital 'B' in 'faceBook' is used to pass visual inspection; actual domain is entirely illegitimate	HIGH
Non-Existent TLD	'.opt' is not a registered IANA TLD — this domain cannot legitimately exist on the public internet	CRITICAL
Credential Harvest Path	'/login.htm' path on a fake domain — designed to collect Facebook username and password	CRITICAL
Social Engineering	'Facebook is down, can you try?' — manufactured pretext to make clicking feel like helping a friend	HIGH
Anonymous Sender	Only 'Vinny' shown — no email domain visible; likely spoofed or a compromised contact	HIGH

CLASSIFICATION: PHISHING | Risk Level: CRITICAL — Credential Harvesting via Lookalike Facebook URL

6. Email 4 — Drop + Koss GMR-54X-ISO Gaming Headset



6.1 Header Summary

From: Adam Markus (forwarding a promotional email from Drop — drop.com)

Subject: Fwd: Drop + Koss GMR-54X-ISO Gaming Headset — Immersive 3D Sound & Comfort All Day Long

Origin: Drop (formerly Massdrop) — legitimate US-based enthusiast marketplace

6.2 Analysis

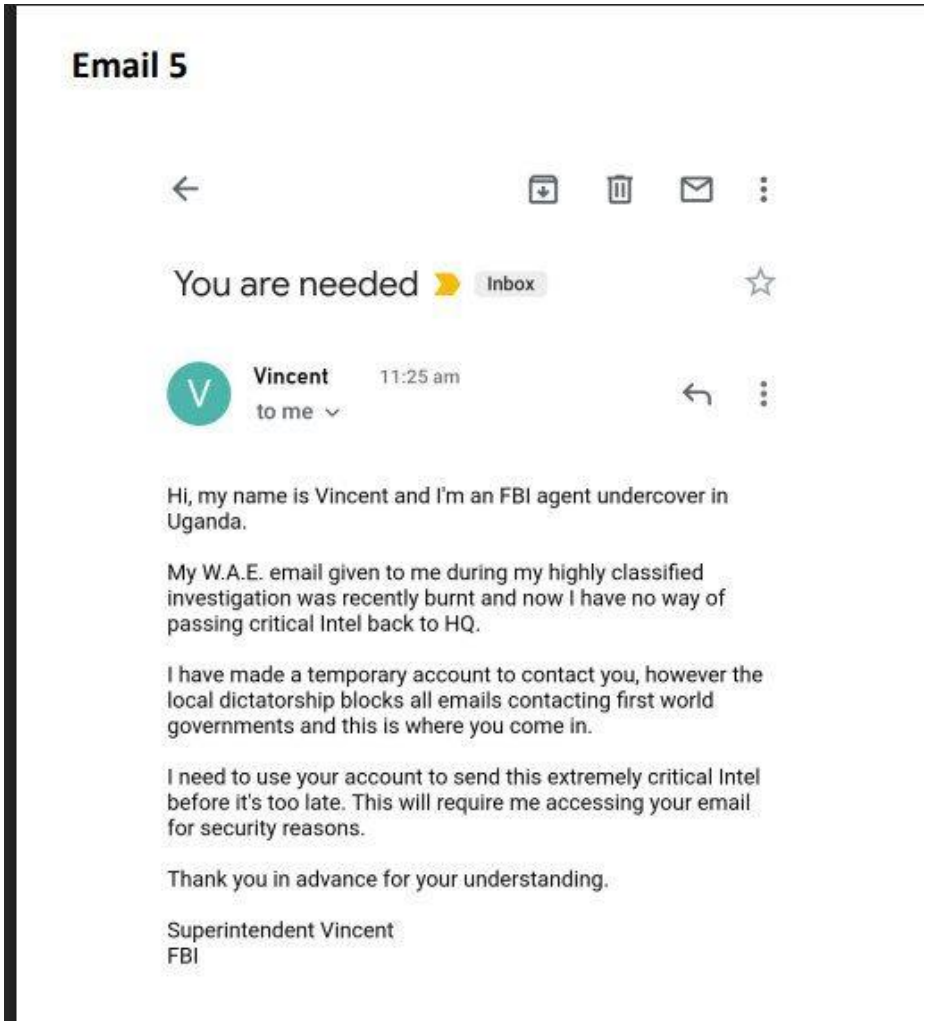
This is a forwarded promotional marketing email from Drop (formerly Massdrop), a legitimate and well-established US-based marketplace specializing in audiophile, gaming, and enthusiast products. The email contains real product information, professional marketing imagery, accurate product descriptions, and a genuine 'See More' CTA linking to the product page on drop.com.

The forwarding chain is visible and traceable. The branding, writing quality, and product detail are all consistent with legitimate commercial email marketing. No credential requests, no urgency language, and no suspicious domains are present.

Indicator	Analysis	Finding
Sender / Origin	Originating from drop.com — verified legitimate e-commerce platform	**CLEAN**
Forwarding Chain	Full forward chain visible with original sender and timestamps intact	**NORMAL**
Content	Accurate, professional product description for a real product — Drop + Koss GMR-54X-ISO	**CLEAN**
Branding	Consistent Drop logo, typography, and marketing layout	**CLEAN**
No Action Demanded	No request for credentials, payment info, or personal data	**CLEAN**

CLASSIFICATION: SAFE | Legitimate promotional/marketing email from verified sender

7. Email 5 — You Are Needed (FBI Agent Scam)



7.1 Header Summary

From: Vincent (display name only)

Subject: You are needed

Claimed Identity: 'Superintendent Vincent — FBI Agent undercover in Uganda'

7.2 Analysis

This is a classic advance-fee / account-takeover social engineering scam. The attacker constructs an elaborate fictional narrative: they are an FBI agent undercover in Uganda, their official email was 'burnt', a local dictatorship is blocking communications, and they urgently need the recipient's email account to relay classified intelligence.

Every element is designed to manufacture urgency, authority, and exclusivity. In practice, granting 'Vincent' email access would result in the account being used for further fraud, credential theft, or as a launchpad for attacks against the victim's contacts. Legitimate law enforcement agencies never contact civilians via personal Gmail accounts to request account access for intelligence operations.

Indicator	Analysis	Severity
Implausible Authority Claim	'FBI agent undercover in Uganda' contacting a civilian via personal email — no legitimate basis	**CRITICAL**
Account Access Request	Requesting victim's email account access — a direct account takeover vector	**CRITICAL**
Manufactured Urgency	'Before it's too late' — artificial time pressure to prevent rational evaluation	**HIGH**
Elaborate False Pretext	Complex narrative (burnt email, dictatorship blocking) designed to seem credible	**HIGH**
Anonymous Sender Domain	No legitimate organization domain — sent from an anonymous personal account	**HIGH**
Flattery & Exclusivity	'This is where you come in' — positions victim as uniquely important to override suspicion	**MEDIUM**

CLASSIFICATION: PHISHING/SCAM | Risk Level: CRITICAL — Social Engineering / Account Takeover Attempt

8. Email 6 — RE: WFH (ANZ Internal Email)

Email 6

Reply Reply All Forward IM

Wed 21/08/2019 2:17 PM

Corrigan, Reuben

RE: WFH

To Bryce, Alan

The project is going well no real problems yet.

The zip file is not ready yet when it is ill send it

Sorry no to coffee I'm busy with the family and will be unavailable all day

Best regards,

Reuben Corrigan | Cyber Security Trainee | Group Technology ANZ
Email - Reuben.corrigan@anz.com
839 Collins Street, Docklands, Victoria 3008, Australia

From: Bryce, Alan
Sent: Wednesday, August 21, 2019 2:11 PM
To: Corrigan, Reuben <Reuben.Corrigan@anz.com>
Subject: WFH

Hey Reuben,

Hope the project is coming along smoothly on your end.

I'll be working from home for the rest of this week as per previous discussion.

Can I get a zip of the workload for this week when you get the chance?

On a side-note; can we get coffee on Sunday arvo to discuss last week's Stand-up? I just wanted to go over a few things.

Kind regards,

Alan Bryce | Cyber Security Analyst | Group Technology ANZ
Email - Alan.Bryce@anz.com
839 Collins Street, Docklands, Victoria 3008, Australia

8.1 Header Summary

From: Reuben Corrigan <Reuben.corrigan@anz.com>

To: Alan Bryce <Alan.Bryce@anz.com>

Subject: RE: WFH

Domain: anz.com — Australia and New Zealand Banking Group (verified corporate domain)

8.2 Analysis

This is an internal corporate email exchange between two colleagues at ANZ (Australia and New Zealand Banking Group). Both parties use verified @anz.com email addresses. The email contains

a professional reply to a routine work-from-home coordination request, with a natural conversational tone covering project status, a zip file delivery, and a coffee catch-up.

Both parties include professional email signatures with name, job title (Cyber Security Trainee / Cyber Security Analyst), company name, physical office address, and the ANZ logo. The conversation is contextually consistent, internally coherent, and contains no requests for credentials or suspicious links.

Indicator	Analysis	Finding
Sender Domain	@anz.com — verified corporate domain of a major APAC bank	**CLEAN**
Recipient Domain	Both parties on the same corporate domain — consistent with internal comms	**CLEAN**
Professional Sigs	Full name, title, company, and address in both signatures — legitimate email footer	**CLEAN**
Content	Routine work update: project progress, WFH coordination, weekend plans	**NORMAL**
No Suspicious Links	No hyperlinks, no attachments referenced that are unexpected or external	**CLEAN**

CLASSIFICATION: SAFE | Legitimate internal corporate email between verified ANZ colleagues

9. Email 7 — Geico Insurance Offer

9.1 Header Summary

From: Val.kill.ma

Claimed Identity: Geico Insurance

Subject: Did you know you can save up to 15% off your car insurance if you switch to Geico?

Embedded URL: hxxp://iwhrhwicy.urlif.y/receipt.php [defanged]

9.2 Analysis

This email claims to offer a Geico car insurance discount but exhibits immediate, severe red flags. The sender domain 'Val.kill.ma' is a .ma (Morocco) domain with a suspicious subdomain structure — Geico is a US insurer and communicates exclusively via @geico.com. The sender name 'Val.kill.ma' with the word 'kill' in it is unusual even by accident.

The embedded URL 'hxxp://iwhrhwicy.urlif.y/receipt.php' (displayed here in defanged format) contains multiple critical indicators: the use of 'hxxp' suggests prior defanging for safety, the domain 'iwhrhwicy.urlif.y' is a randomly generated subdomain with no relation to Geico or insurance, the '.y' suffix is not a recognized TLD, and the path '/receipt.php' has no connection to an insurance quote or discount offer. This URL is likely a malware dropper or credential harvest page.

Indicator	Analysis	Severity
Spoofed Brand	'Geico' impersonation — sender is Val.kill.ma (.ma Morocco TLD), not geico.com	CRITICAL
Suspicious Sender Name	'Val.kill.ma' — contains 'kill' subdomain; clearly not a legitimate insurance sender	HIGH
Obfuscated URL	'hxxp://iwhrhwicy.urlif.y/receipt.php' — randomized subdomain, non-existent TLD, .php payload	CRITICAL
URL-Body Mismatch	Subject promises an insurance discount; URL path is '/receipt.php' — completely unrelated	HIGH
Minimal Body Content	Entire email body is just the URL and 'Cheers, Mike Ferris' — no legitimate offer details	HIGH
No Company Info	No Geico contact info, legal footer, or unsubscribe link — required in all legitimate marketing emails	MEDIUM

CLASSIFICATION: PHISHING | Risk Level: CRITICAL — Brand Impersonation with Malicious URL Payload

10. Consolidated Analysis Summary

The table below provides a consolidated view of all seven samples, their classifications, and the primary indicators identified during analysis.

#	Email / Subject	Sender	Primary Indicator	Risk
1	**FYI (Games Con)**	*Adam John (Gmail)*	No indicators — legitimate friend conversation	SAFE
2	**OneDrive Action Required**	*Venture.ru*	Russian domain impersonating Microsoft, grammar errors	PHISHING
3	**Is Facebook Working?**	*Vinny (anon)*	Lookalike URL: faceBook.com.opt — non-existent TLD	PHISHING
4	**Drop Gaming Headset**	*Drop (drop.com)*	Legitimate promotional email from verified retailer	SAFE
5	**You Are Needed**	*Vincent (anon)*	FBI impersonation scam requesting email account access	SCAM
6	**RE: WFH**	*Reuben.corrigan@anz.com*	Internal corporate email between verified colleagues	SAFE
7	**Geico Insurance Offer**	*Val.kill.ma*	Morocco domain + randomized malicious URL payload	PHISHING

11. Prevention & Awareness Guidelines

Based on the techniques observed across the four phishing samples in this analysis, the following guidelines are recommended for employees and individual users.

11.1 Always Check These Three Things Before Clicking

Before acting on any email, verify:

1. **The sender's domain** — hover over the sender name to reveal the full email address. It must match the organization's official domain exactly (e.g., @microsoft.com, not @venture.ru).
2. **Every link before clicking** — hover over hyperlinks to preview the destination URL. The domain in the URL must match the expected service. Watch for capital letters (faceBook), extra subdomains (.com.opt), or random strings (iwhrhwicy.urlif.y).
3. **Whether the request makes sense** — would Microsoft email you from a .ru domain? Would the FBI contact you via a personal Gmail? If the scenario seems implausible, it almost certainly is.

11.2 Employee Do's

- Report suspected phishing emails to your IT/Security team using the designated reporting channel
- Verify unexpected requests (password resets, account updates, payments) through a known, separate channel — phone the sender directly
- Enable Multi-Factor Authentication (MFA) on all accounts so stolen credentials cannot be used alone
- Check domain registration age for suspicious senders using WHOIS tools — phishing domains are often days old
- Keep browser, OS, and antivirus software updated to reduce malware delivery risk
- Inspect the full sender email address — not just the display name — before trusting any email

11.3 Employee Don'ts

- Never click a link in an email claiming urgency around account suspension, security alerts, or prize notifications
- Never enter your current password into any page linked from an email — legitimate services don't ask for existing passwords
- Never grant email or account access to anyone who requests it via email — regardless of claimed authority
- Never assume an email is safe because it passed your spam filter — as seen in Sample 3 (Facebook), clever URL manipulation bypasses filters

- Never open executable files (.exe, .bat, .js, .vbs) received unsolicited by email
- Never trust a sender's display name alone — always check the full email address behind it

11.4 Organizational Recommendations

- Enforce DMARC p=reject on all corporate domains to prevent domain spoofing attacks like Email 2
- Deploy an email security gateway with real-time URL sandboxing, domain reputation checking, and attachment analysis
- Conduct quarterly simulated phishing campaigns using realistic lures (OneDrive alerts, HR notifications) to train employees
- Provide dedicated training for Finance and HR teams — primary targets of BEC and account takeover attacks
- Establish a zero-trust policy for financial wire transfers: never approve transfers based solely on an emailed request

12. Quick Reference — Phishing Red Flag Card

Print and distribute this reference card to employees as part of security awareness training.

STOP — Red Flags (from this analysis)	GO — Signs of a Legitimate Email
✖ Sender domain doesn't match claimed brand (e.g., Venture.ru claiming to be Microsoft) ✖ URL contains lookalike tricks — capital letters, extra subdomains, unknown TLDs ✖ Random, nonsensical domain in the link (e.g., iwhrhwicy.urlif.y) ✖ Requests to enter existing password or grant account access ✖ Implausible authority figure asking for an unusual favour ✖ Poor grammar or spelling in a 'professional' brand email ✖ Urgency threats: 'before it's too late', 'account will be locked' ✖ Minimal email body with only a link — no legitimate context	✔ Sender domain exactly matches the known organization domain ✔ Both display name and full email address are consistent ✔ Links resolve to expected, well-known domains (hover to verify) ✔ Content is contextually expected — you recognise the relationship ✔ No requests for passwords, credentials, or account access ✔ Professional tone and accurate branding consistent with past comms ✔ Email can be independently verified through a separate channel ✔ Includes proper legal footer, unsubscribe option (for marketing)

13. Tools & Methodology

The following tools were used to investigate and analyze each email sample in this report.

Tool	Purpose	Reference
Google Admin Toolbox	Email header parsing, SPF/DKIM/DMARC authentication evaluation	*toolbox.googleapps.com*
MXToolbox	Header visualization and mail server authentication analysis	*mxtoolbox.com/EmailHeaders*
VirusTotal	URL and domain reputation checking against 90+ threat intelligence feeds	*virustotal.com*
WHOIS / DomainTools	Domain registration age, registrar, and ownership lookup	*whois.domaintools.com*
IPInfo.io	Sending IP geolocation and ASN attribution	*ipinfo.io*
IANA TLD Registry	Verification of Top-Level Domain legitimacy (.opt, .y investigation)	*iana.org/domains/root/db*
Phishing.Database	Cross-reference against known phishing domain blacklists	*Phishing-Database/Phishing.Database*
Browser Developer Tools	Manual URL inspection and link destination verification	*Built-in to Chrome/Firefox*

14. Conclusion

Analysis of the seven real-world email samples collected for this report reveals a consistent pattern: phishing attacks exploit human trust rather than technical vulnerabilities. The four malicious emails each employed at least one of the following core techniques:

- Domain spoofing — using lookalike or unrelated domains to impersonate trusted brands (Emails 2, 3, 7)
- Social engineering narratives — elaborate fictional pretexts to justify unusual requests (Email 5)
- URL obfuscation — manipulating link text and domain structure to defeat casual inspection (Emails 3, 7)
- Brand impersonation — copying visual identity of trusted services (Microsoft, Facebook, Geico) to reduce suspicion (Emails 2, 3, 7)

The three legitimate emails (1, 4, 6) shared common traits: consistent sender domains, expected content, professional formatting, no credential requests, and verifiable sender identities. These characteristics form the baseline against which suspicious emails should be measured.

The most reliable defence against phishing is not technical — it is a trained, sceptical workforce that knows how to pause, inspect, and verify before acting. This report serves as both an analytical reference and a training tool toward that goal.

Report prepared by: Cleveland Henry | Kenyatta University, Nairobi, Kenya | CIN:FIT/MAR26/CS7112 | Future Interns Cybersecurity Internship Programme | Task 2 — Phishing Detection & Awareness GitHub: ClevelandHenry22 | April 2026